



Examen Session Ordinaire : Module Cyber Sécurité -MI-S6 et IA/DI-S4 1h 30 min

Exercice 1 : Questions de Restitution du Cours (6 Points)

1. Définissez brièvement le terme **Rançongiciel (Ransomware)** mentionné dans l'introduction du cours et expliquez quel est son impact principal sur les données d'une victime.
2. Qu'est-ce qu'une attaque **XSS (Cross-Site Scripting)** ? Quel est le type d'élément (ou de code) qu'un attaquant injecte dans l'application web pour cibler les utilisateurs ?
3. Citez les trois piliers fondamentaux de la sécurité informatique qui composent l'acronyme **CIA** et donnez une définition très brève pour chacun d'eux.
4. Quelle est la différence essentielle entre une authentification simple (mot de passe seul) et un mécanisme **MFA / 2FA** (Authentification Multi-Facteurs) ?
5. Définissez l'attaque par **Phishing (Hameçonnage)** et l'attaque par **Smishing**. Quelle est la principale faille humaine exploitée par ces techniques ?
6. Expliquez brièvement en quoi consiste l'attaque du **Rogue Access Point (Point d'accès voyou)** sur un réseau sans fil.

Exercice 2 : Commandes et audit cyber sécurité (7 Points)

Dans le cadre d'un audit de routine, vous devez analyser la sécurité d'un serveur applicatif (IP : 10.0.2.15).

1. En inspectant les connexions actives avec la commande **netstat**, on observe un grand nombre de connexions établies vers des adresses IP inconnues. S'il souhaite vider le cache de résolution DNS pour s'assurer que les futures requêtes partent sur de bonnes bases, quelle option de la commande **ipconfig** doit-il exécuter ?
2. Écrivez la commande **Nmap** permettant de scanner l'ensemble des ports de cette machine tout en activant la **détection de version des services** (comme la version exacte d'Apache ou de SSH) pour identifier de potentielles failles.
3. Si la machine cible possède un pare-feu qui bloque les paquets de requêtes Écho ICMP (Ping), le scan classique peut marquer l'hôte comme inactif (*Host seems down*). Quelle option spécifique de Nmap devez-vous utiliser pour contourner cette vérification et forcer l'analyse ?
4. Après exécution, Nmap affiche qu'un port est dans l'état Filtered (Filtré). Qu'est-ce que cela signifie concrètement concernant la structure de sécurité présente devant ce port ?

Exercice 3 : Analyse de Vulnérabilités Web (7 Points)

Un site internet universitaire possède un champ d'injection potentiel dans son formulaire de connexion. Le script vulnérable est formulé ainsi :

```
$query = "SELECT * FROM utilisateurs WHERE login = '" . $_POST['user'] . "' AND passe = '" . $_POST['password'] . "'";
```

1. Quelle chaîne d'injection SQL classique (à base de fermeture de guillemets et de condition toujours vraie) un étudiant peut-il insérer dans le champ user pour se connecter en tant qu'administrateur sans connaître le mot de passe ?

2. Si ce même site permet aux étudiants de poster des messages sur un forum d'entraide sans filtrer les balises HTML, un attaquant y insère le code suivant :
`<script>alert(document.cookie);</script>`.
 - De quel type d'attaque (XSS Reflétée ou XSS Stockée) s'agit-il ici ?
 - Quel est le danger principal de l'accès au document.cookie ?
3. Pour remédier à la fois aux injections SQL et aux failles XSS, le cours préconise de ne jamais faire confiance aux entrées utilisateurs. Citez et expliquez brièvement **deux mécanismes de défense** distincts (un pour le SQL, un pour le XSS) permettant de neutraliser ces attaques.